



Security Analysis of Smart Contract Languages

BENCHMARK REPRODUTÍVEL SOBRE O OWASP SMART CONTRACT TOP 10

Martim Redondo & Rúben Silva

UNIVERSIDADE DO MINHO



Objetivo

- **STATE OF THE ART:** SEGURANÇA NA ETHEREUM VIRTUAL MACHINE
- **ANÁLISE QUANTITATIVA:** EFICÁCIA REAL DAS FERRAMENTAS DE SEGURANÇA





Decisões

OWASP TOP 10

- ATUALIZADO;
- GRANULARIDADE DE FINA.
- “MANUAL PRÁTICO”

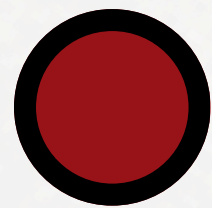
SOLIDITY / EVM

- DOMÍNIO DO ECOSSISTEMA;
- COBERTURA TAXONÓMICA;
- MATURIDADE DE TOOLING.



As 10 Categorias OWASP

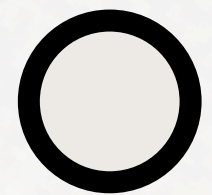
SC01 Access Control	SC02 Business Logic	SC03 Oracle Manipulation	SC04 Flash Loans	SC05 Input Validation
SC06 Unchecked Calls	SC07 Arithmetic	SC08 Reentrancy	SC09 Overflow/Underflow	SC10 Proxy/Upgradeability



LINGUAGEM (SOLIDITY)



EVM (BYTECODE)



PROTOCOLO (ECONÓMICO/CONSENSO)



MVE

```
contracts > OWASP_01 > MVE_O1_Vuln.sol > ...
1  // SPDX-License-Identifier: MIT
2  pragma solidity ^0.8.20;
3
4  contract MVE_O1_Vuln {
5      address public owner;
6      address payable public treasury;
7
8      constructor() {
9          owner = msg.sender;
10         treasury = payable(msg.sender);
11     }
12
13     function deposit() external payable {}
14
15     // [VULN] Sem controle de acesso, qualquer endereco pode trocar a treasury.
16     function setTreasury(address payable newTreasury) external {
17         treasury = newTreasury;
18     }
19
20     // [VULN] Qualquer utilizador pode disparar o levantamento total para a treasury manipulada.
21     function emergencyWithdraw() external {
22         (bool ok, ) = treasury.call{value: address(this).balance}("");
23         // [REVERT] "transfer failed" se a transferencia externa falhar.
24         require(ok, "transfer failed");
25     }
26 }
```

VULNERABLE



```
// SPDX-License-Identifier: MIT
pragma solidity ^0.8.20;

contract MVE_O1_Fixed {
    address public owner;
    address payable public treasury;

    error NotOwner();
    error InvalidTreasury();

    modifier onlyOwner() {
        // [FIX] Restringe funcoes criticas ao owner.
        if (msg.sender != owner) revert NotOwner();
        _;
    }

    constructor() {
        owner = msg.sender;
        treasury = payable(msg.sender);
    }

    function deposit() external payable {}

    function setTreasury(address payable newTreasury) external onlyOwner {
        // [FIX] Valida input para evitar treasury invalida.
        if (newTreasury == address(0)) revert InvalidTreasury();
        treasury = newTreasury;
    }

    function emergencyWithdraw() external onlyOwner {
        (bool ok, ) = treasury.call{value: address(this).balance}("");
        // [REVERT] "transfer failed" se a transferencia falhar.
        require(ok, "transfer failed");
    }
}
```

FIXED



Resultados: Ferramentas Gerais

Ferramenta	Tipo	TP (Vuln)	FP (Fixed)
Slither	Estática	7/15	15/15
Aderyn	Estática	3/15	7/15
Semgrep	Estática	0/15	0/15
Solhint	Estática	0/15	0/15
Mythril	Simbólica	6/15	10/15
Halmos	Formal	2/2	0/2
Echidna	Fuzzing	10/15	0/15
Medusa	Fuzzing	10/15	1/15

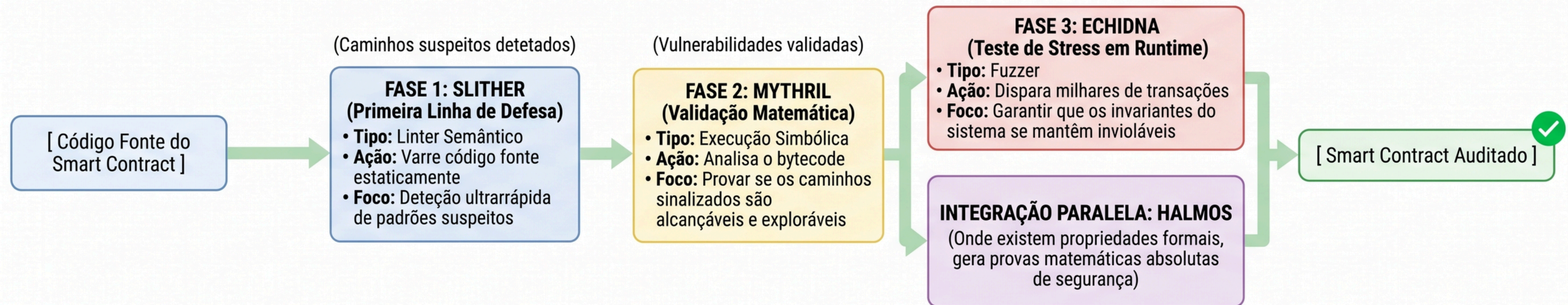


Resultados: LLMs

Modelo	Vuln avg	Fixed avg	Δ
LLaMA-3.3-70B	3.5	6.8	+3.3
Qwen3-32B	3.3	6.2	+2.9
Gemini 2.5 Flash	2.5	3.9	+1.4

NOTAS:

- ESCALA 1–10 (10 = PERFEITAMENTE SEGURO).
- Δ = CAPACIDADE DE DISCRIMINAR VULN/FIXED.





Conclusão

- **APRENDIZAGEM:**
 - NENHUMA FERRAMENTA GARANTE PROTEÇÃO ISOLADA
 - É FUNDAMENTAL ENCADEAR VÁRIOS PARADIGMAS
- **LIMITAÇÕES:** VULNERABILIDADES ISOLADAS $\neq$ SISTEMA EM PRODUÇÃO
- **TRABALHO FUTURO:**
 - TESTAR A PIPELINE EM PRODUÇÃO DEFI
 - EXPANDIR OS MÉTODOS DE TESTAGEM
 - REFINAR OS MODELOS DE IA



Security Analysis of Smart Contract Languages

BENCHMARK REPRODUTÍVEL SOBRE O OWASP SMART CONTRACT TOP 10

Martim Redondo & Rúben Silva

UNIVERSIDADE DO MINHO